Impacto	Valor
Crítico	4
Alto	3
Medio	2
Bajo	1

Probabilidad	Valor
Muy alta	4
Alta	3
Media	2
Baja	1

Nivel de riesgo
Bajo
Medio
Alto
Crítico

Mapa de calor

Impacto \ Prob	Baja	Media	Alta	Muy Alta	Total
Crítico	2	5	2	1	10
Alto	1	4	2	0	7
Medio	1	3	1	0	5
Bajo	1	1	1	0	3
Total	5	13	6	1	25

Nivel	Cantidad
Crítico	5
Alto	10
Medio	7
Bajo	3
Total	**25**

Puntos mínimos
1
3
6
9

Rank	IS	Driagrama/Elemento	STRIDE
1	T-01	N1 / P3	Spoofing
2	T-02	N1 / F2	Tampering
3	T-03	N2 / P4.2	Tampering
4	T-04	N2 / P4.2	Elevation of Privilege
5	T-08	N0 / E4	Spoofing
6	T-05	N1 / D2	Information Disclosure
7	T-06	N1 / P8	Elevation of Privilege
8	T-07	N2 / Q1	Tampering
9	T-12	N0 / E5	Information Disclosure
10	T-14	N1 / D5	Information Disclosure
11	T-09	N1 / P9	Repudiation
12	T-10	N1 / P2	Denial of Service
13	T-11	N1 / D3	Spoofing
14	T-15	N1 / P1	Tampering
15	T-13	N1 / D4	Information Disclosure
16	T-16	N1 / P6	Denial of Service
17	T-21	N0 / E3	Tampering
18	T-17	N2 / P4.4	Repudiation
19	T-20	N0 / E2	Spoofing
20	T-23	N1 / P1	Information Disclosure
21	T-18	N1 / D1	Information Disclosure
22	T-19	N1 / P2	Information Disclosure
23	T-22	N1 / D3	Denial of Service
24	T-24	N0 / E6	Information Disclosure
25	T-25	N0 / E4	Denial of Service

Amenaza	Impacto	Probabilidad
Toma de cuenta por credential stuffing, phishing en tiempo real o MFA débil	Crítico	Muy Alta
Manipulación de monto o destino en tránsito	Crítico	Alta
BOLA/IDOR: operar sobre cuentas ajenas	Crítico	Alta
Evasión de step-up y límites (BFLA, endpoints legacy)	Alto	Alta
Intercepción de OTP por SIM swap o malware	Alto	Alta
Inyección SQL y exfiltración masiva	Crítico	Media
Abuso de privilegios por insider sin doble aprobación	Crítico	Media
Manipulación o repetición (replay) de mensajes en la cola	Crítico	Media
Brecha en proveedor KYC que expone documentos de identidad	Crítico	Media
Secretos expuestos en repositorios, variables o imágenes	Crítico	Media
Logs sin integridad: negación de operaciones	Alto	Media
DDoS o scraping por ausencia de rate limiting	Alto	Media
Secuestro de sesión o token sin rotación ni revocación	Alto	Media
App reempaquetada o SDK de terceros comprometido	Alto	Media
Datos sensibles en logs en texto claro	Medio	Alta
Saturación del core por picos desde canales digitales	Crítico	Baja
Alteración o suplantación de mensajes con la red ACH	Crítico	Baja
Cliente niega una transferencia (sin firma de transacción)	Medio	Media
Suplantación de operador por credenciales compartidas	Medio	Media
Datos sensibles en almacenamiento local o capturas de pantalla	Medio	Media
Hashes de contraseña expuestos con algoritmo débil	Alto	Baja
Errores verbosos y cabeceras que revelan tecnología	Bajo	Alta
Agotamiento de caché y caída de sesiones	Medio	Baja
Reportes de auditoría con PII sin controles	Bajo	Media
Saturación del proveedor SMS: OTP no entregados	Bajo	Baja

Puntos	Nivel	Responsable
16	Crítico	CISO / Líder de Identidad
12	Crítico	Líder de Arquitectura / Móvil
12	Crítico	Líder de Desarrollo
9	Crítico	Desarrollo + Arquitectura
9	Crítico	Seguridad + Canales
8	Alto	Desarrollo / DBA
8	Alto	Seguridad / TI
8	Alto	Arquitectura / Middleware
8	Alto	Gestión de Terceros
8	Alto	DevSecOps
6	Alto	Seguridad / SOC
6	Alto	Infraestructura / Redes
6	Alto	Desarrollo / Identidad
6	Alto	Móvil / DevSecOps
6	Alto	Desarrollo / DevSecOps
4	Medio	Infraestructura / Core
4	Medio	Arquitectura / Middleware
4	Medio	Desarrollo
4	Medio	Seguridad / TI
4	Medio	Móvil
3	Medio	Desarrollo / DBA
3	Medio	Desarrollo / DevSecOps
2	Bajo	Infraestructura
2	Bajo	Seguridad / Cumplimiento
1	Bajo	Gestión de Terceros

Acción correctiva
MFA resistente a phishing, rate limiting adaptativo y verificación de credenciales filtradas
TLS 1.3 y validaciones server-side (hito 1: 07/01/2027); pinning y firma de transacción (hito 2)
Autorización por objeto, identificadores UUID y pruebas en CI
Autorización centralizada, retiro de API v1, step-up obligatorio
Migrar OTP por SMS a push/TOTP/FIDO2
Parametrización, mínimo privilegio en BD y monitoreo de actividad
PAM y doble aprobación en backoffice
mTLS, firma de mensajes e idempotencia
Evaluación del proveedor, minimización y tokenización
Bóveda de secretos y escaneo pre-commit
Logs inmutables con ID de correlación y NTP
Anti-DDoS, rate limiting y autoscaling
Tokens de vida corta, rotación y cookies seguras
Attestation, ofuscación y SCA/SBOM
Enmascaramiento de datos sensibles en logs
Pruebas de carga y circuit breakers
Mensajería firmada con la red ACH
Firma de transacción verificable
Credenciales nominales con MFA
Protección del almacenamiento local
Hash robusto con sal (Argon2id o bcrypt)
Errores genéricos y cabeceras seguras
Dimensionamiento de la caché
Enmascarar PII en reportes exportados
SLA y proveedor alterno de SMS

Fecha objetivo	Estado
07/01/2027	Abierto
07/04/2027	Abierto
07/01/2027	Abierto
07/01/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/10/2027	Abierto
07/01/2027	Abierto
07/04/2027	Abierto
07/01/2027	Abierto
07/01/2027	Abierto
07/04/2027	Abierto
07/01/2027	Abierto
07/10/2027	Abierto
07/10/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/01/2027	Abierto
07/10/2027	Abierto
07/10/2027	Abierto
07/10/2027	Abierto

Rank	ID	Diagrama/Elemento	STRIDE
1	T-01	N1 / P3	Spoofing
2	T-02	N1 / F2	Tampering
3	T-03	N2 / P4.2	Tampering
4	T-04	N2 / P4.2	Elevation of Privilege
5	T-08	N0 / E4	Spoofing
6	T-05	N1 / D2	Information Disclosure
7	T-06	N1 / P8	Elevation of Privilege
8	T-07	N2 / Q1	Tampering
9	T-12	N0 / E5	Information Disclosure
10	T-14	N1 / D5	Information Disclosure

Amenaza	Impacto	Probabilidad
Toma de cuenta por credential stuffing, phishing en tiempo real o MFA débil	Crítico	Muy Alta
Manipulación de monto o destino en tránsito	Crítico	Alta
BOLA/IDOR: operar sobre cuentas ajenas	Crítico	Alta
Evasión de step-up y límites (BFLA, endpoints legacy)	Alto	Alta
Intercepción de OTP por SIM swap o malware	Alto	Alta
Inyección SQL y exfiltración masiva	Crítico	Media
Abuso de privilegios por insider sin doble aprobación	Crítico	Media
Manipulación o repetición (replay) de mensajes en la cola	Crítico	Media
Brecha en proveedor KYC que expone documentos de identidad	Crítico	Media
Secretos expuestos en repositorios, variables o imágenes	Crítico	Media

Puntos	Nivel	Responsable
16	Crítico	CISO / Líder de Identidad
12	Crítico	Líder de Arquitectura / Móvil
12	Crítico	Líder de Desarrollo
9	Crítico	Desarrollo + Arquitectura
9	Crítico	Seguridad + Canales
8	Alto	Desarrollo / DBA
8	Alto	Seguridad / TI
8	Alto	Arquitectura / Middleware
8	Alto	Gestión de Terceros
8	Alto	DevSecOps

Acción Correctiva
MFA resistente a phishing, rate limiting adaptativo y verificación de credenciales filtradas
TLS 1.3 y validaciones server-side (hito 1: 07/01/2027); pinning y firma de transacción (hito 2)
Autorización por objeto, identificadores UUID y pruebas en CI
Autorización centralizada, retiro de API v1, step-up obligatorio
Migrar OTP por SMS a push/TOTP/FIDO2
Parametrización, mínimo privilegio en BD y monitoreo de actividad
PAM y doble aprobación en backoffice
mTLS, firma de mensajes e idempotencia
Evaluación del proveedor, minimización y tokenización
Bóveda de secretos y escaneo pre-commit

Fecha Objetivo	Estado
07/01/2027	Abierto
07/04/2027	Abierto
07/01/2027	Abierto
07/01/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/04/2027	Abierto
07/10/2027	Abierto
07/01/2027	Abierto